

NETWORK LEVEL ATTACKS AND COUNTERMEASURES (PART 1)

Types of Sniffing

Sniffing

Used by network administrators to perform network analysis, troubleshoot network issues, and monitor network sessions. Attackers used sniffing techniques to covertly investigate and capture critical information being transmitted in a network.

Packet Sniffing

The process of monitoring and capturing all data packets passing through a given network using a software application or hardware device. Sniffing is straightforward in hub-based networks, as the traffic on a segment passes through all the hosts associated with that segment. However, most networks today work on switches.

A **switch** is an advanced computer networking device. The major difference between a hub and a switch is that a **hub** transmits line data to each port on the machine and has no line mapping, whereas a **switch** looks at the Media Access Control (MAC) address associated with each frame passing through it and sends the data to the required port. A **MAC address** is a hardware address that uniquely identifies each node of a network.

An attacker needs to manipulate the functionality of the switch to see all the traffic passing through it. A packet sniffing program (also known as a **sniffer**) can capture data packets only from within a given subnet, which means that it cannot sniff packets from another network. Often, any laptop can plug into a network and gain access to it. Many enterprises' switch ports are open. A packet sniffer placed on a network in promiscuous mode can therefore capture and analyze all the network traffic. Sniffing programs disable the filter used by Ethernet network interface cards (NICs) to prevent the host machine from seeing the traffic of other stations. Thus, sniffing programs can monitor all traffic.

How Sniffer Works



Once a switch turns into a hub, it starts broadcasting all packets it receives to all the computers in the network. By default, promiscuous mode is turned off in network machines; therefore, the NICs accept only those packets that are addressed to a user's machine and discard the packets sent to other machines. A sniffer turns the NIC of a system to promiscuous mode so that it listens to all the data transmitted on its segment. A sniffer can constantly monitor all the network traffic to a computer through the NIC by decoding the information encapsulated in the data packets. Attackers configure the NIC in their machines to run in promiscuous mode so that the card starts accepting all the packets. Thus, the attacker can view all the packets that are being transmitted in the network.

There are two (2) basic types of Ethernet environments, and sniffers work differently in each. These two types are:

- **Shared Ethernet**

In a shared Ethernet environment, a single bus connects all the hosts that compete for bandwidth. In this environment, all the other machines receive packets meant for one machine. Thus, when machine 1 wants to talk to machine 2, it sends a packet out on the network with the destination MAC address of machine 2, along with its own source MAC address.

The other machines in the shared Ethernet (machines 3 and 4) compare the frame's destination MAC address with their own and discard the unmatched frame. However, a machine running a sniffer ignores this rule and accepts all the frames. Sniffing in a shared Ethernet environment is passive and, hence, difficult to detect.

- **Switched Ethernet**

In a switched Ethernet environment, the hosts connect with a switch instead of a hub. The switch maintains a table that tracks each computer's MAC address and the physical port on which that MAC address is connected, and then delivers packets destined for a particular machine. The switch is a device that sends packets to the destination computer only; furthermore, it does not broadcast them to all the computers on the network.

This results in better utilization of the available bandwidth and improved security. Hence, the process of putting a machine NIC into promiscuous mode to gather packets does not work. As a result, many people think that switched networks are secure and immune to sniffing. However, this is not true.

Types of Sniffing

Attackers run sniffers to convert the host system's NIC to promiscuous mode. The NIC in promiscuous mode can then capture packets addressed to the specific network.

There are two types of sniffing. Each is used for different kinds of networks.

Passive Sniffing

This involves sending no packets. It simply captures and monitors the packets flowing in the network. A packet sniffer alone is not preferred for an attack because it works only in a common collision domain. A common collision domain is the sector of the network that is not switched or bridged (i.e., connected through a hub).

Common collision domains are present in hub environments. A network that uses hubs to connect systems uses passive sniffing. In such networks, all hosts in the network can see all the traffic. Hence, it is easy to capture traffic through the hub using passive sniffing.

Attackers use the following passive sniffing methods to gain control over a target network:

- **Compromising physical security:** An attacker who succeeds in compromising the physical security of a target organization can walk into the organization with a laptop and try to plug into the network and capture sensitive information about the organization.
- **Using a Trojan horse:** Most Trojans have in-built sniffing capability. An attacker can install these on a victim's machine to compromise it. After compromising the victim's machine, the attacker can install a packet sniffer and perform sniffing.

Most modern networks use switches instead of hubs. A switch eliminates the risk of passive sniffing. However, a switch is still vulnerable to active sniffing. Passive sniffing provides significant stealth advantages over active sniffing.

Active Sniffing

This searches for traffic on a switched LAN by actively injecting traffic into it. This also refers to sniffing through a switch. In active sniffing, the switched Ethernet does not transmit information to all systems connected through the LAN as it does in a hub-based network. For this reason, a passive sniffer is unable to sniff data on a switched network. It is easy to detect these sniffer programs and highly difficult to perform this type of sniffing.

How Attackers Hack the Network Using Sniffers

Attackers use sniffing tools to sniff packets and monitor network traffic on a target network. The steps that an attacker follows to make use of sniffers to hack a network are illustrated below.

- **Step 1:** An attacker who decides to hack a network first discovers the appropriate switch to access the network and connects a system or laptop to one of the ports on the switch.
- **Step 2:** An attacker who succeeds in connecting to the network tries to determine network information, such as the topology of the network, by using network discovery tools.
- **Step 3:** By analyzing the network topology, the attacker identifies the victim's machine to target their attacks.
- **Step 4:** An attacker who identifies a target machine uses ARP spoofing techniques to send fake (spoofed) Address Resolution Protocol (ARP) messages.
- **Step 5:** The previous step helps the attacker divert all the traffic from the victim's computer to the attacker's computer. This is a typical man-in-the-middle (MITM) type of attack.
- **Step 6:** Now, the attacker can see all the data packets sent and received by the victim. The attacker can now extract sensitive information from the packets, such as passwords, usernames, credit card details, and PINs.

Various Sniffing Techniques and Tools

Attackers use various sniffing techniques, such as MAC attacks, DHCP attacks, ARP poisoning, spoofing attacks, and DNS poisoning, to steal and manipulate sensitive data. Attackers use these techniques to gain control over a target network by reading captured data packets and then using that information to break into the network.

MAC Flooding: A technique used to compromise the security of network switches that connect network segments or devices. Attackers use the MAC flooding technique to force a switch to act as a hub so that they can easily sniff the traffic.

DHCP Starvation Attack: A configuration protocol that assigns valid IP addresses to host systems from a pre-assigned DHCP pool. In a DHCP starvation attack, an attacker floods the DHCP server by sending numerous DHCP requests and uses all available IP addresses that the DHCP server can issue. As a result, the server cannot issue any more IP addresses, leading to a DoS attack. Because of this issue, valid users cannot obtain or renew their IP addresses; thus, they fail to access their network.

An attacker broadcasts DHCP requests with spoofed MAC addresses with the help of tools such as Yersinia, Hyenae, and Gobbler.

ARP Spoofing Attack: A protocol used for mapping an IP address to a physical machine address that is recognized in the local network. ARP packets can be forged to send data to the attacker's machine. ARP spoofing involves constructing a large number of forged ARP request and reply packets to overload a switch.

When a machine sends an ARP request, it assumes that the ARP reply will come from the right machine. ARP provides no means of verifying the authenticity of the responding device. Even systems that have not made an ARP request can accept the ARP replies coming from other devices. Attackers use this flaw in ARP to create malformed ARP replies containing spoofed IP and MAC addresses. Attackers flood a target computer's ARP cache with forged entries; this is also known as **poisoning**. ARP spoofing is an intermediary for performing attacks such as DoS, MITM, and session hijacking.

MAC Spoofing/Duplicating: MAC duplicating refers to spoofing a MAC address with the MAC address of a legitimate user on the network. A MAC duplicating attack involves sniffing a network for MAC addresses of legitimate clients connected to the network.

In this attack, the attacker first retrieves the MAC addresses of clients who are actively associated with the switch port. Then, the attacker spoofs a MAC address with the MAC address of the legitimate client. If the spoofing is successful, then the attacker can receive all the traffic destined for the client. Thus, an attacker can gain access to the network and take over the identity of someone on the network.

DNS Poisoning: The protocol that translates a domain name (e.g., www.eccouncil.org) into an IP address (e.g., 208.66.172.56). The protocol uses DNS tables that contain the domain name and its equivalent IP address stored in a distributed, large database. In DNS poisoning, also known as **DNS spoofing**, the attacker tricks a DNS server into believing that it has received authentic information when, in reality, it has not received any. The attacker tries to redirect the victim to a malicious server instead of the legitimate server.

The attacker does this by manipulating the DNS table entries in the DNS. This results in the substitution of a false IP address at the DNS level, where web addresses are converted into numeric IP addresses.

Sniffing Tools

System administrators use automated tools to monitor their network, but attackers misuse these tools to sniff network data.

Wireshark

Captures and interactively browses the traffic running on a computer network. This tool uses WinPcap to capture packets on its own supported networks. It captures live network traffic from Ethernet, IEEE 802.11, PPP/HDLC, ATM, Bluetooth, USB, Token Ring, Frame Relay, and FDDI networks.

The captured files can be programmatically edited via the command line. A set of filters for customized data display can be refined using a display filter. Attackers use Wireshark to sniff and analyze the packet flow in the target network and extract critical information about the target.

Here are additional tools:

- **SteelCentral Packet Analyzer:** A high-performance network traffic analyzer that helps visualize, monitor, and troubleshoot network performance issues.
- **Capsa Network Analyzer:** A packet-sniffing and protocol-analysis tool used for real-time network monitoring, troubleshooting, and security analysis.
- **Observer Analyzer:** A network performance monitoring solution that captures, decodes, and analyzes network traffic for diagnostics.
- **PRTG Network Monitor:** A comprehensive network monitoring tool that tracks bandwidth usage, uptime, and packet data for performance management.
- **SolarWinds Deep Packet Inspection and Analysis:** A tool that inspects and analyzes packet-level traffic to identify applications, troubleshoot slowdowns, and detect anomalies.

Different Sniffing Countermeasures

Listed below are some of the countermeasures to be followed to defend against sniffing:

- Restrict physical access to the network media to ensure that a packet sniffer cannot be installed
- Use end-to-end encryption to protect confidential information
- Permanently add the MAC address of the gateway to the ARP cache
- Use static IP addresses and ARP tables to prevent attackers from adding the spoofed ARP entries
- Turn off network identification broadcasts and, if possible, restrict the network to authorized users to protect the network from being discovered with sniffing tools
- Use IPv6 instead of IPv4
- Use encrypted sessions such as SSH instead of telnet, Secure Copy (SCP) instead of FTP, and SSL for email connection to protect wireless network users against sniffing attacks
- Use HTTPS instead of HTTP to protect usernames and passwords
- Use a switch instead of the hub, as a switch delivers data only to the intended recipient
- Use Secure File Transfer Protocol (SFTP) instead of FTP for secure transfer of files
- Use PGP and S/MIME, VPN, IPsec, SSL/TLS, SSH, and one-time passwords (OTP)
- Use POP2 or POP3 instead of POP to download emails from email servers
- Use SNMPv3 instead of SNMPv1 and SNMPv2 to manage networked devices
- Always encrypt the wireless traffic with a strong encryption protocol such as WPA or WPA2
- Retrieve MAC addresses directly from NICs instead of the OS; this prevents MAC address spoofing
- Use tools to determine if any NICs are running in promiscuous mode
- Use the concept of Access Control List (ACL) to allow access only to a fixed range of trusted IP addresses in a network
- Change default passwords to complex passwords
- Avoid broadcasting SSIDs (Session Set Identifiers)
- Implement a MAC filtering mechanism on your router
- Implement network scanning and monitoring tools to detect malicious intrusions, rogue devices, and sniffers connected to the network

Reference:

EC-Council. (2021). *Ethical hacking essentials* (1st ed.). EC-Council.